

(주)하랑케이터링 수탁사 개선 방안 보고서

수탁사 (피감사)	(주)하랑케이터링
위탁사 (감사 주체)	(주)하랑항공
위탁 업무 범위	항공기 기내식 제조·탑재 및 특수식 분류·포장·배송
점검 기간	2026년 01월 26일 ~ 2026년 02월 13일
작성일	2026년 02월 23일

본 보고서는 (주)다온컨택의 개인정보 보호 관리 수준을 점검한 결과를 바탕으로,
각 취약 사항에 대한 구체적인 개선방안과 이행 계획을 기술한 문서입니다.

목차

1. 개선방안 요약	3
1.1 보안 준수율 분류 기준	3
1.2 조치 기한 분류 기준	3
2. 범주별 개선방안 상세	4
2.1 내부 관리 계획 및 조직	4
2.2 접근 통제 및 권한 관리	5
2.3 접속기록 보관 및 점검	5
2.4 비밀번호 관리	6
2.5 접속 보안 및 네트워크	6
2.6 단말기 보안	7
2.7 개인정보 암호화 및 출력 통제	8
2.8 개인정보 생명주기	9
3. 이행 점검 로드맵	10
4. 결론 및 향후 조치 계획	11
4.1 향후 조치 일정	11

1. 개선방안 요약

1.1 보안 준수율 분류 기준

분류	양호(Y)	부분양호(P)	취약(N)
점수	1	0.7	0

총점	100 ~ 90	89 ~ 70	69 ~ 50	49 ~ 0
등급	A	B	C	D

- 각 점검항목을 양호, 부분양호, 취약으로 평가하여 분류한다.
- 총점은 53개의 점검항목 점수의 합산을 100점 만점으로 환산한 값이다.
- 환산 점수에 따라 90점 이상 A등급, 70~89점 B등급, 50~69점 C등급, 49점 이하 D등급으로 산정한다.

1.2 조치 기한 분류 기준

구분	긴급	단기	중기
조치 기한	4주	2개월	6개월

- 지적 사항의 심각도에 따라 조치기한을 3단계로 구분한다.
- 개선방안 이행은 긴급, 단기, 중기 순으로 추진한다.

2. 범주별 개선방안 상세

2.1 내부 관리 계획 및 조직

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
계정·권한 관리	직무와 무관한 민감 기능 권한 부여 및 외부 인력 과도 권한 부여 사례 존재, 권한 오남용 점검 이력 부족	직무 기반 접근통제(RBAC) 정책 수립 및 민감 기능 권한 재설계, 외부 인력 권한 최소화 적용, 월 1회 권한 점검 프로세스 도입	IT인프라팀장 김기영
권한 승인 통제	승인 문서와 실제 권한 부여 내역 불일치, 구두 승인 및 사후 승인 관행, 공용 단말 계정 공유	전자결재 기반 사전 승인 의무화, 긴급 계정 발급 시 사후 승인 기한(24시간 이내) 설정, 공용 계정 사용 금지 및 개인 계정 전환 추진	IT인프라팀장 김기영
계정 회수 관리	퇴사자 계정 장기 미삭제 및 권한 미회수, 인사-계정 시스템 연동 부재	HR 시스템 연동 자동 계정 비활성화 구축, 퇴사 당일 계정 삭제 정책 적용, 월 1회 잔존 계정 점검 수행	IT인프라팀장 김기영

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
DB 관리자 접근 통제	애플리케이션에 DB 관리자 계정 접속 여부 점검 미흡	DB 접근 통제 정책 수립 및 Bastion Host 도입, 관리자 계정 분리 및 접근 로그 상시 점검 체계 구축	IT인프라팀장 김기영
공용계정 운영	생산/배송 현장에서 공용계정 사용 및 책임추적성 부족	공용계정 단계적 폐지 및 개인 계정 전환 계획 수립, 불가피한 경우 사용 사유·기간·책임자 승인 기록 의무화	IT인프라팀장 김기영
인증 체계	관리자 계정만 MFA 적용, 전사 적용 미흡	전사 계정 대상 MFA(OTP/SMS) 확대 적용 및 정책 표준화	보안팀장 유승범

2.2 접근 통제 및 권한 관리

점검 결과 등급: C

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
출입통제 관리	장비 반출입 기록 누락, 서버실 출입 기록 불일치, 번호키 공유	출입통제 시스템 전자화 및 로그 자동 기록, 번호키 개인별 관리 또는 카드/지문 인증 전환	시설관리팀장 최종윤 IT인프라팀장 김기영
물리적 보안	모바일 단말 보관 기준 미흡, 키 관리대장 기록 누락	단말 잠금장치 및 보관 기준 수립, 키 관리대장 운영 표준화 및 월 1회 점검	총무팀장 하무열
출력물 관리	출력물 무결성 보장 미흡 및 폐기 통제 미흡	보안 Seal 적용 및 출력물 관리대장 운영, 파쇄 폐기 절차(SOP) 수립 및 전사 교육 실시	보안팀장 유승범

2.3 접속기록 보관 및 점검

점검 결과 등급: C

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
로그 점검 체계	월 단위 점검 미흡 및 이상행위 기준 미정의	월 1회 정기 점검 의무화, 이상행위 탐지 기준 문서화 및 점검 보고서 체계 수립	보안팀장 유승범

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
로그 보관 정책	로그 보관 기준 불명확 (민감정보 포함)	로그 보관기간 최소 3년으로 정책 상향 및 적용	IT인프라팀장 김기영
추적성 확보	일부 구간 사용자 행위 추적성 미흡	사용자 단위 로그 수집 강화 및 공용단말 사용자 식별 로그 개선	IT인프라팀장 김기영

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
로그 무결성 및 백업	백업 체계 미흡 및 무결성 검증 부족	중앙 로그 서버 구축, 주 1회 자동 백업 체계 수립, 해시 기반 무결성 검증 적용	IT인프라팀장 김기영
보안 모니터링	SIEM 미운영	SIEM 도입 및 이상행위 자동 탐지 체계 구축	보안팀장 유승범

2.4 비밀번호 관리

점검 결과 등급: A

해당 항목 전체 양호 판정으로 현재 시점 개선 필요 사항 없음

2.5 접속 보안 및 네트워크

점검 결과 등급: B

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
정보유출 통제	클립보드, 이메일, 클라우드 통한 정보 유출 통제 미흡	VDI 클립보드 차단 적용, 개인 이메일 및 클라우드 접근 차단 정책 수립	IT인프라팀장 김기영
예외구간 관리	배송팀 등 네트워크 통제 예외 구간 존재	예외 구간 별도 보안 정책 수립 및 접근통제 강화	IT인프라팀장 김기영

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
DLP 미도입	정보유출 탐지 체계 부재, 현장 배송팀 예외 구간 존재	DLP 솔루션 도입 및 정책 적용파일 용량·확장자 제한 정책 적용	보안팀장 유승범

2.6 단말기 보안

점검 결과 등급: C

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
보안패치	일부 단말 보안패치 미적용	전 단말 최신 패치 적용 및 미적용 단말 즉시 조치	IT인프라팀장 김기영
단말 반출입	단말 반출입 기록 누락	반출입 관리대장 즉시 재정비 및 누락 방지 체계 구축	IT인프라팀장 김기영

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
USB 통제	USB 통제 정책 부분 적용	전사 USB 쓰기 차단 정책 전체 적용 및 예외 승인 절차 수립	IT인프라팀장 김기영
단말 관리	PDA 보관 기준 미흡	모바일 단말 보관 및 잠금장치 기준 수립	총무팀장 하무열

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
로그 및 이상탐지	이상행위 기준 및 로그 무결성 검증 미흡	단말 로그 수집 및 이상행위 탐지 기준 수립, 무결성 검증 체계 구축	보안팀장 유승범

2.7 개인정보 암호화 및 출력 통제

점검 결과 등급: C

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
암호화 적용	일부 구간 암호화 적용 여부 불명확	암호화 대상 전수 점검 및 미적용 구간 암호화 적용	개인정보보호팀장 류태현
전송 통제	이메일 등 수기 전송 존재	파일 전송 정책 수립 및 암호화 전송 의무화	IT인프라팀장 김기영
비정형 파일	DRM 미적용 및 파일 암호화 누락	DRM 도입 및 비정형 파일 암호화 정책 적용	보안팀장 유승범

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
키 관리	암호화 키 관리 체계 미흡	KMS 도입 및 키 관리 정책 수립	보안팀장 유승범
평문 데이터	DB 평문 데이터 존재	AES-256 암호화 적용 및 데이터 마이그레이션 수행	개발팀장 문석표

2.8 개인정보 생명주기

점검 결과 등급: C

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
제3자 제공	관리대장 기록 누락	제3자 제공 관리대장 운영 의무화 및 정기 점검	개인정보보호팀장 류태현
파기 관리	파기 결과 보고 미이행	파기 결과 자동 보고 체계 구축 및 담당자 지정	개인정보보호팀장 류태현

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
생명주기 관리	보존기간 미설정 및 자동 파기 미흡	보존기간 정책 수립 및 자동 파기 시스템 구축	개인정보보호팀장 류태현

3. 이행 점검 로드맵

개선방안 이행은 아래 3단계 로드맵에 따라 추진하며, 각 단계 완료 시 (주)하랑항공 개인정보보호팀에 이행 결과를 보고한다.

각 단계 완료 후 이행 결과보고서(증적자료 포함)를 (주)하랑항공 개인정보보호팀장에게 제출한다.

이행 중 기술적 제약, 예산 문제 등으로 일정 변경이 필요한 경우 사전 협의 후 서면 승인을 득하여야 한다.

단계	기간	주요 이행 항목	이행 결과 보고 기한
긴급 조치	~2026.04.30	퇴사자 ERP/CMS 계정 즉시 삭제 / 공용계정 개인계정 전환 착수 / 관리자 포털 비밀번호 암호화 적용 / 파기 정책 수립 및 소급 보고 / 접속기록 월 1회 검토 체계화 / 보안패치 미적용 단말 조치 / 권한 승인 프로세스 정비	2026년 05월 12일
단기 조치	~2026.07.12	내부관리계획서 현행화 / 출력물 관리 SOP 재수립 / 클립보드 차단 / 개인 이메일-클라우드 접근 차단 / 제3자 제공 관리대장 기록 재개 / 파기 결과 보고 자동화 / 재위탁 계약서 보완 / SFTP 전환 / 보안패치 추적 프로세스 정비	2026년 07월 12일
중기 조치	~2026.10.12	DB 임시테이블 평문 잔존 조치 완료 확인 / 암호화 키 관리대장 수립 및 KMS 도입 검토 / SIEM 솔루션 도입 / DLP 정책 적용 / 재위탁 계약서 보완 및 보안 점검 / 개인정보 생명주기 전수 매핑 완료	2026년 10월 12일
재점검	2026.11월 중	(주)하랑항공 현장 재점검 실시 — 전 항목 이행 완료 여부 및 잔존 취약점 재확인	2026년 11월 중

4. 결론 및 향후 조치 계획

(주)하랑케이터링은 이번 점검에서 확인된 총 32건(취약 11건, 부분양호 21건)의 취약 사항에 대한 구체적인 개선방안을 수립하여 이행할 책임이 있다. 특히 퇴사자 계정은 미삭제 및 권한 미회수, 인사-계정 시스템 연동 부재, 일부 단말 보안패치 미적용, 단말 반출입 기록 누락 등은 긴급 조치 사항으로서 4주 이내에 반드시 처리해야하는 항목들이다.

위탁사인 (주)하랑항공은 수탁사의 이행 상황을 아래 일정에 따라 모니터링하고, 이행이 지연되거나 불충분한 경우 계약 조항에 따라 필요한 조치를 취할 수 있다.

4.1 향후 조치 일정

구분	일정	내용
조치계획서 제출	2026년 04월 29일까지	(주)하랑케이터링 → (주)하랑항공 제출 (담당자 서명 필수)
긴급 항목 이행 보고	2026년 05월 12일까지	직무 기반 권한 재정비, 퇴사자·이동자 계정 회수, 전자결재 기반 권한 승인 통제 강화, 월 1회 접속기록 점검 체계 수립, 미적용 단말 보안패치 완료, 단말 반출입 관리대장 재정비 결과 보고
단기 항목 이행 보고	2026년 07월 12일까지	DB 관리자 접근통제 체계 수립, 공용계정 개인계정 전환 계획 수립 및 이행 착수, MFA 확대 적용, 출입통제·장비 반출입 관리 절차 개선, 출력물 관리 및 폐기 SOP 수립, 로그 3년 보관 정책 적용, 개인 이메일·클라우드·클립보드 차단, USB 통제 강화, 제3자 제공 및 파기관리 체계 개선 결과 보고
중기 항목 이행 보고	2026년 10월 12일까지	중앙 로그 서버 구축, 로그 백업·무결성 검증 체계 수립, SIEM 및 DLP 도입 추진, KMS 기반 암호화 키 관리 체계 마련, DB 평문 데이터 암호화 조치, 개인정보 보존기간 설정 및 자동 파기 체계 구축 결과 보고
현장 재점검	2026년 11월 중	(주)하랑항공 주관 현장 재점검 실시 (전 항목 이행 여부 및 잔존 취약점 확인)